

御网智元 技术报告

初审冲刺版 v0.5.0 | 2026-08-28

提交单位：_____ 参赛队员：_____

摘要

御网智元是面向授权附件与回环靶场的单机自托管网络安全智能体工作台。它将自然语言任务、受控工具、不可变 Run、持久化证据和独立确定性 Judge 组织成闭环。模型输出只能提出下一步，不能自行宣布验证成功。

1. 任务理解与闭环架构

初审聚焦复杂、开放、非结构化安全任务中的规划、执行与可追溯性。系统通过正式 HTTP 消息入口接收目标、授权范围、附件和黄金案例标识；Run 冻结 Provider、Agent、工具、权限、目标和输入附件。FastAPI、TaskSpec/Run/Artifact/ExecutionStep/Evidence、AgentEngine、Tool Registry、SQLite 与 Judge 分层协作，所有评测只读取持久化事实。

2. 黄金案例与证据绑定

每次黄金 Run 持久化 case_id、case_version、objective SHA-256、请求 SHA-256、输入 Artifact SHA-256、授权范围摘要和工具快照摘要。evaluate_golden_run 拒绝未绑定、绑定不一致或不属于当前案例的相似 Run；Judge 私有配置不进入 Agent Prompt。该机制避免将相似执行或模型自述误计为成功。

3. 三个无害本地案例

A：受控 ZIP 附件从读取、解包、提取、解码到 FlagCandidateVerifyTool。未真实调用最终验证工具时 AgentEngine 拒绝完成并要求重规划，Judge 再绑定候选哈希和真实工具结果。

B：仅允许 localhost 和冻结 URL 范围，按线索动态选择 HTTP 证据与解析工具，Judge 将 Flag 证据绑定到解码链。

C：分别判定平台识别/拒绝注入影响，以及 Agent 拒绝后使用附件检查工具完成授权摘要。不再由服务端补写 safety.recovered；摘要必须关联 file_inspect 或 strings_extract 成功证据。

4. 工具协同与安全边界

ToolSpec、Registry 与 Executor 统一输入、输出、权限、目标类型、风险、超时和 Artifact 引用；内置、插件和 MCP 使用同一契约，中风险需审批，高风险默认拒绝。CSV 限制行、列和字段长度；ZIP/TAR 限制条目、展开总量、压缩比并拒绝路径穿越、非普通条目和格式冲突。系统不提供任意 Shell、未授权公网扫描、自动攻击或外部平台提交。

5. 工程、创新与参考

Docker Compose、健康检查、隔离黄金命名卷和直接可执行的 doctor/status/stop 脚本支持单机复现；黄金 Compose 不依赖外部预创建 volume。创新主张限定为不可变快照、黄金绑定、工具事实验证、注入拒绝与恢复双证据及评测索引，不宣称外部榜单性能领先。

参考来源：官方赛题 PDF 与赛题解读 PPTX (访问日期 2026-08-28)；NYU CTF Bench、D-CIPHER、BoxPwnr、HackSynth、AutoPenBench、CyberGym、PentestGPT 公开资料 (同日访问)，仅用于研究边界对照。

负责人签字：_____ 单位盖章：_____ 日期：_____